MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 040 · SEPTEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

EXPLAINER · VULNERABILITY MANAGEMENT

Vulnerability Scanning Under NIST 800-171: How Often Is Enough?

Vulnerability scanning under NIST 800-171 has no fixed cadence. You set it, and 3.11.2 and 3.14.1 assess whether you wrote it down and kept it.

BY **PATRICK CARUSO**

READING TIME · 7 MIN

VULNERABILITY-MANAGEMENT · PATCH-MANAGEMENT · NIST-800-171 · CMMC

The most common answer a defense contractor gives about vulnerability scanning under NIST 800-171 is also the most reasonable-sounding one: we patch every month, we run a scan every quarter the way the PCI shops do, and the standard never asks for more. On the letter of the text, that answer is harder to knock down than its critics admit. Requirement 3.11.2 says to scan "periodically and when new vulnerabilities affecting those systems and applications are identified." It names no interval, no scanner, no deadline. An assessor who fails a company for choosing quarterly over monthly would be enforcing a number the regulation never wrote.

That position deserves a fair hearing, and then it deserves to lose. The cadence was never the assessor's question. The question is whether you defined one, whether you kept it, and whether a calendar was the only thing that ever made you look.

FIELD COPY
ISSUE Nº 040
VULNERABILITY MANAGEMENT

14

SPRS POINTS RIDING ON FOUR REQUIREMENTS - 3.11.2 AND 3.14.1 AT 5 EACH, 3.11.1 AT 3, 3.11.3 AT 1

15

800-171A ASSESSMENT OBJECTIVES ACROSS THOSE FOUR, AND ONE UNMET OBJECTIVE COSTS THE FULL DEDUCTION

14 days

THE LONGEST A FEDERAL CIVILIAN AGENCY MAY LEAVE ANY KEV-LISTED VULNERABILITY OPEN UNDER CISA'S BOD 26-04

The number NIST 800-171 leaves blank is the one you get graded on

Here is the direct answer to how often you should run a vulnerability scan for CMMC: as often as your own written policy says, plus every time a new vulnerability affecting your systems is identified, and you must be able to prove both. NIST SP 800-171A breaks 3.11.2 into five objectives. The first asks whether the scanning frequency is defined. The next two ask whether scans run at that frequency against CUI systems and against applications containing CUI; the last two ask the same about scans run when new vulnerabilities are identified. Miss any one of the five and the DoD Assessment Methodology takes the full 5 points; there is no partial credit for four out of five.

That structure dismantles the defense from the inside. "Periodically" does mean whatever you like, but only after you have said what you like, in a document, with a number in it. A policy that reads "scans are performed regularly" fails objective one before anyone opens a scan report. A policy that says "quarterly" and a scan history showing February, then July, fails objective two. And the quarterly calendar, however faithfully kept, has nothing to say about objectives four and five: when a vendor publishes an emergency advisory for a product inside your boundary, a scan scheduled for next month is not a scan run when the vulnerability was identified.

The neighbors carry weight too: 3.11.1, periodic risk assessment, is worth 3 points and also starts by asking whether its frequency is defined; 3.11.3, remediation in accordance with that assessment, is worth 1. The heavyweight is 3.14.1, identify, report, and correct system flaws in a timely manner, at 5 points, and its six objectives are three pairs of the same demand: specify the time frame to identify flaws, then meet it; specify the time frame to report them, then meet it; specify the time frame to correct them, then meet it. Neither "timely" nor "periodically" is a standard until you supply the number.

A patch cycle is not a vulnerability scanning program

The monthly-patch argument quietly treats two controls as one. Patching answers 3.14.1's correction objectives for the software your patch tool manages. Scanning, under 3.11.2, is how you find out what the patch tool never touched: the third-party application nobody enrolled, the failed install that reported success, the appliance firmware. The Rev 2

discussion for 3.11.2 is specific about the blind spot, telling organizations to make sure networked printers, scanners, and copiers are not overlooked. A patch cycle can run flawlessly for a year and never see a copier.

The quarterly-scan half of the position fails on its own borrowed logic. Programs that cite PCI rarely cite all of it: PCI DSS 4.0 requires internal scans at least every three months and, under requirement 11.3.1.2, requires those internal scans to be authenticated, with systems that cannot accept credentials documented. The difference matters more than the interval. An unauthenticated scan sees a host the way an outsider does, through open ports and the version strings services choose to announce. It cannot read installed packages or the registry, so it guesses from banners and misses whatever does not listen on the network. A short report reads as a clean one to anyone who does not know how it was produced. The Rev 2 discussion anticipates this too, noting that authorizing privileged access to selected components is what makes a thorough scan possible.

An unauthenticated scan does not tell you how many vulnerabilities you have. It tells you how many your network was willing to announce.

A credentialed scan also surfaces configuration findings alongside missing patches, and those belong to your baseline program rather than your patch queue; how baselines are set and evidenced is its own discipline, and MacTech's free STIG reference server returns the actual check and fix text for a flagged setting instead of a paraphrase.

◆ BOD 22-01 IS NO LONGER THE BENCHMARK

Guidance still circulating cites BOD 22-01's two-week and six-month deadlines for KEV entries. CISA revoked that directive on 10 June 2026 and replaced it with BOD 26-04, which sets deadlines from exposure, exploitation, automatability, and technical impact. BOD 26-04 binds federal civilian agencies, not contractors unless their contract says so, and it excludes certain ~~Department of War systems~~. Cite it as a benchmark you chose, never as an obligation you owe.

Remediation deadlines are a promise the assessor will hold you to

Once you accept that 3.14.1 grades you against your own time frames, the temptation runs the other way: write generous deadlines you can never miss. A remediation schedule is a documented risk decision, and it has to survive the question of why a known, actively exploited flaw was allowed to sit for ninety days.

The most defensible external yardstick comes from CISA, with a correction the market has not fully absorbed: BOD 22-01, still widely cited for its Known Exploited Vulnerabilities deadlines, is revoked. Its replacement, BOD 26-04, issued 10 June 2026, trades severity-only thinking for four questions: is the asset publicly exposed, is the vulnerability in the KEV catalog, can an adversary automate the exploit, and does exploitation yield partial or total control. The answers produce calendar-day deadlines of 3 days (some with a forensic triage of the asset), 14 days, 60 days, or fix on the next system upgrade. Every KEV-listed vulnerability lands at 14 days or fewer, even on an internal asset. The directive binds federal civilian agencies and says outright that it does not apply to contractors unless the procurement contract directs it, so nothing in it is your obligation. That is what makes it useful: a policy that says "we adopted CISA's BOD 26-04 decision criteria as our remediation standard" is a decision an assessor can follow and a contracting officer can respect.

It also finishes off the monthly patch cycle as a complete answer. A flaw added to the KEV catalog the day after Patch Tuesday waits most of a month for the next cycle, roughly twice the ceiling CISA sets for its own agencies.

When a fix genuinely cannot land on time, the difference between a finding and a decision is paperwork: an exception with a named owner, a reason, a compensating control, and an expiry date. Where a requirement ends up formally NOT MET, the POA&M rules decide the rest, and they are unforgiving here. Under 32 CFR 170.21 nothing above 1 point may sit on a Level 2 POA&M outside a single encryption exception, so 3.11.2 and 3.14.1 cannot be deferred to one at all; the eligibility and closeout rules are laid out in what you can put on a POA&M.

The trail an assessor pulls, and the parameter Rev 3 makes explicit

Start with a policy or SSP section carrying actual numbers: scan frequency, the event triggers for an out-of-cycle scan, and remediation time frames by risk tier. Scan reports whose dates match that frequency and whose headers show credentialed coverage, with the uncredentialed hosts listed and explained. Tickets tying a specific finding to a specific fix with timestamps, so an assessor can measure elapsed days against your own deadline. An exception register for everything that missed. An assessor sampling this trail is doing arithmetic, and a readiness assessment is mostly the same arithmetic done early, while the dates can still be fixed.

NIST SP 800-171 Rev 3 removes the ambiguity outright: its requirement 03.11.02 turns scan frequency, remediation response times, and the update interval for vulnerabilities to be scanned into organization-defined parameters. DoD contracts and SPRS still bind to Rev 2, but Rev 3 is a plain statement of what Rev 2 was already asking.

We patch monthly, the argument went, so we are covered. The honest reply is that monthly is a perfectly good number, once it is written down, measured against, paired with a credentialed scan, and overridden the day CISA says a flaw inside your boundary is being exploited. ◆

MORE ISSUES

mactechsolutionsllc.com/maczine

new field copies with every merge

WORK WITH US

CMMC readiness · CUI enclaves · RMF

mactechsolutionsllc.com/contact

MACZINE

Written, reviewed and versioned in the open.

Published from Git, reviewed like code.